ACTIVIDAD 18 – MODELO DIAMANTE

CNO V

EDWIN ADMAEL CASTILLO GÓMEZ 181700
CARLOS RENÉ CASTILLO OLVERA 182033
DIEGO OSVALDO HERNÁNDEZ FERNÁNDEZ 182217
TRISTAN RIVERA MAGDALENAYESENIA 174702

Parte 01. Comprensión del modelo.

Se completó la tabla conceptual definiendo cada elemento del Modelo Diamante y asignando un ejemplo práctico correspondiente a escenarios reales de ciberseguridad.

Elemento	Descripción	Ejemplo práctico
Adversario	Se define como el actor de amenaza, individuo o grupo responsable de dirigir y ejecutar la intrusión cibernética para alcanzar un objetivo específico (financiero, espionaje, sabotaje).	Se identifica a un grupo de tipo APT (Amenaza Persistente Avanzada) o a un atacante externo (Red Team/Black Hat) motivado por la exfiltración de información confidencial.
Capacidad	Se refiere al conjunto de herramientas, técnicas, tácticas y procedimientos (TTPs) desarrollados o adquiridos que el adversario utiliza para llevar a cabo la intrusión o el ataque.	Se empleó el desarrollo de un *payload* malicioso para explotación de vulnerabilidades, o el uso de técnicas de inyección SQL (SQLi) para la extracción de registros en una base de datos.
Infraestructura	Se describe como la estructura física y/o lógica (direcciones IP, nombres de dominio, servidores, redes) empleada por el adversario para controlar las capacidades, enviar *malware* y mantener la comunicación.	Se observó el despliegue de un servidor privado virtual (VPS) configurado para actuar como servidor de Comando y Control (C2), junto con dominios ofuscados para campañas de *phishing*.
Víctima	Se establece como el objetivo principal del ataque, pudiendo ser una persona, una organización entera, un servidor de red, un activo de información o una dirección de correo electrónico específica.	Se determinó que el objetivo comprometido fue un servidor de bases de datos interno o las credenciales de acceso de un administrador de sistemas dentro de una organización.

Parte 02. Análisis de evento (modelo diamante)

Se realizó el desglose del incidente detectado en la organización, donde se identificó comportamiento anómalo relacionado con la ejecución de código malicioso y comunicaciones hacia infraestructura externa. A continuación, se detallan las metacaracterísticas que estructuran este evento:

Metacaracterística	Descripción del evento
Marca de tiempo	Se registró en el momento de la detección del comportamiento anómalo por parte de los sistemas de monitoreo y la posterior alerta de los equipos infectados tras la ejecución del *malware*.

Metacaracterística	Descripción del evento
Fase	El evento se sitúa predominantemente en la fase de **Comando y Control (C2)** y **Acciones sobre los Objetivos**, dado que el análisis revela una comunicación establecida con dominios externos.
Resultado	Se confirmó la ejecución exitosa del código malicioso en los sistemas de la víctima, logrando la resolución de dominios externos y el establecimiento de túneles de comunicación bidireccional.
Dirección	Se identificó un flujo de tráfico de red originado desde el interior de la infraestructura organizacional (red interna) hacia direcciones IP externas y dominios de control remotos.
Metodología	Se utilizó la técnica de balizamiento (*beaconing*) y resolución de nombres de dominio dinámicos para evadir controles de seguridad y mantener la persistencia en los equipos comprometidos.
Recursos	Se emplearon herramientas de análisis de red para la revisión de *logs*, bases de datos de **WHOIS** para la atribución de infraestructura y motores de detección de *malware* para la identificación del agente.

Análisis detallado del escenario

A partir de los hallazgos técnicos y la correlación de datos de red, se determinaron los siguientes puntos clave sobre la intrusión:

1. ¿Quién es el adversario en este escenario?

Se determinó que el adversario es un actor de amenaza externo, cuya ubicación u origen fue rastreado preliminarmente mediante el uso de herramientas de **WHOIS/IP**. La naturaleza de la infraestructura sugiere un actor con la capacidad de registrar dominios específicos y gestionar servidores de control para campañas de distribución de *malware*.

2. ¿Cuál es la capacidad utilizada?

La capacidad principal consistió en el desarrollo y despliegue de una variante de *malware* con funciones avanzadas de comunicación. Este agente malicioso tiene la facultad de evadir detecciones básicas, realizar consultas DNS para resolver dominios de control y establecer conexiones persistentes hacia el exterior para recibir instrucciones adicionales.

3. ¿Qué tipo de infraestructura se emplea?

Se identificó una infraestructura híbrida compuesta por nombres de dominio específicamente registrados para el ataque y una serie de direcciones IP externas que actúan como nodos de terminación para el tráfico C2. Estos activos representan la capa lógica que permite al adversario interactuar con los sistemas comprometidos sin necesidad de exposición directa.

4. ¿Quién es la víctima primaria?

La víctima primaria se definió como la organización afectada, específicamente los equipos y terminales de red donde se detectó inicialmente el comportamiento anómalo. El impacto se centralizó en los activos de información internos que fueron utilizados como punto de entrada para la ejecución del código.

5. ¿Existe evidencia de movimiento lateral?

Se concluyó que existe evidencia clara de movimiento lateral o propagación interna. Esta deducción se fundamentó en el análisis de los registros de red (*logs*), los cuales mostraron que múltiples *hosts* internos, y no solo el equipo inicial, estaban intentando establecer conexiones hacia las mismas direcciones IP externas, lo que indica una distribución del compromiso dentro de la red local.

Parte 03. Relación con la Kill Chain

Se realizó la correlación de los eventos identificados durante el incidente con las fases correspondientes del modelo *Cyber Kill Chain* (Cadena de Eliminación Cibernética de Lockheed Martin). Se analizó la naturaleza de cada evento para posicionarlo cronológica y tácticamente dentro del ciclo de vida del ataque.

Evento	**Fase Kill Chain**
Detección de malware	**Instalación / Acciones sobre los objetivos** *(Fase de respuesta)*
Envío de phishing	**Entrega (Delivery)**
Conexión a C2	**Comando y Control (Command and Control - C2)**
Ejecución del malware	**Explotación / Instalación (Exploitation & Installation)**

Justificación técnica de la clasificación

Para dotar de mayor profundidad al análisis, se documentó el razonamiento detrás de cada clasificación:

- **Envío de phishing (Entrega - Delivery):** Se determinó que este evento corresponde íntegramente a la fase de *Entrega*. Representa el vector de transmisión y el mecanismo táctico que el adversario seleccionó para trasladar el arma cibernética (*payload* o enlace malicioso) desde su infraestructura hasta el entorno de la víctima primaria, utilizando en este caso la ingeniería social corporativa como medio de transporte.
- **Ejecución del malware (Explotación / Instalación - Exploitation & Installation):** Se clasificó el evento bajo estas fases continuas. Tras la interacción de la víctima con el vector de entrega, se procede a la *Explotación* (aprovechamiento de fallos humanos o técnicos para detonar el código) y la consecuente *Instalación*. En esta etapa, el agente malicioso se ancla en el sistema operativo, modificando registros o creando servicios para asegurar persistencia antes de comunicarse con el exterior.
- **Conexión a C2 (Comando y Control - Command and Control):** Se vinculó de forma directa y unívoca con la fase de *Comando y Control*. Se observó que, una vez

establecido en el *host*, el *malware* inicia comunicaciones salientes hacia las direcciones IP externas para abrir un canal bidireccional (túnel). Esto permite al atacante administrar el equipo comprometido de forma remota y exfiltrar datos de manera estructurada.

- **Detección de malware (Instalación / Acciones sobre los objetivos):** Se precisó que la "detección" constituye un evento defensivo (Blue Team) y no una acción ofensiva per se dentro de la cadena del adversario. Sin embargo, el comportamiento que originó dicha detección se ubica tácticamente en las fases avanzadas (Instalación, C2 o Acciones sobre los objetivos). Se concluyó que los sistemas de monitoreo lograron identificar la intrusión debido a las anomalías generadas por los binarios en memoria o el tráfico inusual hacia el exterior.

Parte 04. Hilos de actividad

Se procedió a mapear el escenario de Amenaza Persistente Avanzada (APT) utilizando la metodología de hilos de actividad (Activity Threads) del Modelo Diamante. Esto permitió visualizar la secuencia de eventos, la correlación entre múltiples intrusiones y la evolución de la infraestructura del adversario a medida que el ataque progresó dentro de la red.

Representación esquemática de los hilos (Diagrama lógico)

Se estructuró el siguiente flujo lógico para ilustrar la cadena de eventos y la intersección entre las víctimas:

AQUÍ VAN LOS HILOS

Descripción detallada del análisis de hilos

A partir del modelo esquemático, se elaboró la descripción técnica de cada fase de la intrusión, desglosando el comportamiento del adversario y la afectación de los activos.

Hilo 1 (Víctima 1 - Compromiso inicial del administrador) Se determinó que el primer hilo de actividad se concentra en la brecha del perímetro y la obtención de acceso inicial. El análisis de este hilo revela lo siguiente:

- **Vector de entrada:** El adversario dirigió una campaña de ingeniería social altamente segmentada (*Spear Phishing*) hacia un usuario con altos privilegios (Administrador).
- **Ejecución y Persistencia:** Tras la interacción del usuario con la carga útil (*payload*), se documentó la ejecución silenciosa del *malware* en la estación de trabajo. Este código malicioso estableció mecanismos de persistencia en el sistema operativo.
- **Comunicaciones C2:** Se observó que el equipo comprometido inició comunicaciones cifradas de salida hacia la infraestructura de Comando y Control (C2) del atacante. En este punto, el Hilo 1 se consolida, ya que el adversario ha logrado control remoto total sobre la estación del administrador, estableciendo una cabeza de playa (*beachhead*) dentro de la red corporativa.

Relación entre ambos (Pivoting - Movimiento Lateral) Se identificó una transición crítica en el modelo diamante donde un vértice cambia de naturaleza lógica. En esta fase, la estación de

trabajo de la Víctima 1 dejó de ser únicamente el objetivo de un ataque para convertirse en parte integral de la infraestructura del adversario.

- **Técnica de Proxy:** El atacante reconfiguró el *host* del administrador para que funcionara como un nodo *proxy*. Esto permitió enrutar el tráfico malicioso a través de una máquina interna de confianza, evadiendo así los sistemas de prevención de intrusiones (IPS) perimetrales y ocultando la verdadera dirección IP del adversario durante las siguientes fases del ataque.

Hilo 2 (Víctima 2 - Expansión y compromiso secundario) Se concluyó que el segundo hilo de actividad emana directamente desde el interior de la red, utilizando el acceso privilegiado y la confianza inherente de la máquina de la Víctima 1.

- **Identificación del objetivo:** Utilizando la estación del administrador como punto de lanzamiento, el adversario realizó labores de reconocimiento interno para identificar activos críticos (Víctima 2), los cuales podrían ser servidores de bases de datos, controladores de dominio o repositorios de información confidencial.

- **Ejecución del ataque secundario:** Se documentó un ataque originado desde la IP interna del administrador hacia la Víctima 2. Dado que el tráfico provino de un segmento de red confiable y bajo el contexto de credenciales administrativas comprometidas, los controles de seguridad internos fueron anulados, logrando el compromiso exitoso del segundo objetivo. Este hilo finaliza con la consolidación del adversario sobre el activo de mayor valor.